

Documentación de Seguridad y Resiliencia

Sistema de Leads VIP con Propuestas (HITL) · Nicolas Navarro

1. Minimización y protección de datos

El sistema solo recolecta los campos estrictamente necesarios para calificar un lead y redactar una propuesta: **Nombre, Email, Empresa, Mensaje Original y Presupuesto Estimado**. No se piden ni almacenan datos sensibles (documento de identidad, datos de pago, información de salud, etc.) que no aportan nada a la tarea.

Retención: la única fuente de verdad es una base de Airtable propiedad del autor; no hay exports automáticos ni réplicas de la base. Fuera de Airtable, cada proveedor recibe solo lo necesario para su función (tabla siguiente). Dentro de Airtable, el registro de un error por datos incompletos guarda en "Detalle Tecnico" los campos que sí llegaron, para poder diagnosticarlo; al borrar un lead conviene borrar también sus errores vinculados.

Proveedor	Qué recibe	Para qué
Anthropic (Claude)	Nombre, Empresa, Presupuesto y Mensaje del lead	Clasificar VIP y redactar la propuesta (no recibe el Email).
Slack	Nombre, Empresa, VIP, confianza y texto de la propuesta; en la confirmación del hilo, el email de destino	Que el equipo revise la propuesta antes de aprobarla y sepa a quién se envió.
Gmail	Email del lead y texto de la propuesta	Envío final, solo después de la aprobación humana.

Sin datos hardcoded: ningún nodo contiene datos de un lead escritos a mano. Todo el contenido variable viaja por expresiones dinámicas que leen el registro actual de Airtable, por ejemplo `{{ $( "Releer Lead (Estado Actual)".item.json.fields.Nombre ) }}`. El único texto fijo es el catálogo de servicios y las instrucciones de tono y formato, que son configuración del negocio, no datos de clientes.

Credenciales: las claves de Airtable, Anthropic, Slack y Gmail están guardadas en el almacén de credenciales de n8n. El workflow solo las referencia por ID y nombre: el export (`blueprint_raw.json`) no contiene ninguna clave ni token.

2. Rutas de error y salvaguardas (resiliencia)

2.1 Guard anti-reprocesamiento: cada lead se procesa una sola vez

Después de cualquier trigger, el flujo relee el lead en Airtable ("Releer Lead (Estado Actual)") y el nodo **"Guard: ¿Sigue Pendiente?"** solo lo deja continuar si su estado *actual* es "Pendiente". Un lead en Procesado por IA, Aprobado por Humano, Enviado, Rechazado o Error termina en "Omitir: Lead Ya Procesado", sin llamar a la IA, sin crear una segunda propuesta y sin volver a escribirle al cliente.

La salvaguarda surgió de una falla real detectada en pruebas: al ejecutar manualmente el trigger de Airtable desde el editor, n8n ignora la fórmula de filtro y devuelve el primer registro de la tabla, aunque ya esté procesado. En una corrida eso reprocesó un lead ya enviado (propuesta duplicada y estado sobrescrito). Con el guard, el mismo caso termina en 628 ms sin efectos (ejecución #755). Además, para

probar un lead puntual se agregó el webhook de prueba (POST /webhook/leads-vip-prueba con { "lead_id": "rec..." }), que pasa por el mismo guard.

2.2 Validación de datos antes de gastar en IA

“Detectar Campos Faltantes” calcula qué campos obligatorios están vacíos (Nombre, Email, Mensaje Original) y “Validar Datos Completos” solo deja pasar al lead si no falta ninguno. Si falta algo, el lead nunca llega a la IA: se registra en la tabla Errores con el detalle exacto (ej.: “*Datos incompletos: falta Email, Mensaje Original*”) y el lead pasa a Estado = Error. Así se evitan dos problemas a la vez: gastar tokens en una llamada inútil y que un prompt con datos vacíos genere una propuesta sin sentido (ejecución #751).

2.3 Manejo de fallos de la API de Claude

El nodo “Calificar y Redactar Propuesta” tiene configurado `onError: continueErrorOutput`. Si la llamada a Anthropic falla (timeout, rate limit, error de la API) o la respuesta no respeta el esquema JSON del Structured Output Parser, el flujo no se corta en silencio: la rama de error registra el mensaje en la tabla Errores (vinculado al lead) y marca el lead como Estado = Error, dejando un rastro claro para la revisión manual.

2.4 Límite contra bucles infinitos en el HITL

“Pausa: Esperar Aprobación” espera 1 minuto y “Releer Propuesta” vuelve a consultar el checkbox “Aprobado”. Sin un límite, un lead que nadie aprueba quedaría reintentando para siempre. “Filtro: ¿Excedió Intentos?” usa `$runIndex` (el índice de corrida del propio nodo) y, en la 5.^a vuelta (`$runIndex ≥ 4`), corta el ciclo: marca el lead como Rechazado y registra el timeout en Errores (ejecución #754, 5 min 10 s). Además, el sistema responde en el hilo de Slack del aviso que la propuesta no se envió.

2.5 Alcance de esta cobertura y riesgos conocidos

Las cuatro salvaguardas anteriores cubren los puntos de falla más probables: reprocesar un lead, datos de entrada incompletos, la llamada a la IA y el HITL sin respuesta. Quedan fuera de este alcance, documentados como extensiones para una siguiente iteración:

- **Fallos de escritura en Airtable, Slack o Gmail** (por ejemplo, un rate limit momentáneo): esos nodos no tienen rama de error propia. La ejecución quedaría marcada como fallida en el historial de n8n, pero no se registraría automáticamente en la tabla Errores. La extensión natural es un *error workflow* de n8n que la registre.
- **Webhook de prueba sin autenticación:** quien conozca la URL y el ID de un lead podría dispararlo. El impacto está acotado por el guard (solo procesa leads en “Pendiente”, que el trigger procesaría igual) y nunca envía nada sin aprobación humana. En producción se recomienda desactivar ese nodo o protegerlo con Header Auth.
- **Concurrencia:** si dos ejecuciones tomaran el mismo lead exactamente al mismo tiempo, ambas podrían pasar el guard antes de que la primera cambie el estado. Con un único trigger en producción que consulta cada 5 minutos (el webhook es solo de prueba), el escenario es improbable; se podría eliminar marcando el lead como “en proceso” inmediatamente después del guard.

3. Puntos de Human-in-the-loop

El sistema tiene un único punto crítico donde una acción irreversible (contactar a un cliente real) podría ejecutarse sola: el envío de la propuesta por Gmail. Para evitar el “efecto metralleta” (que la IA le escriba directamente a un cliente sin que nadie lo revise), el flujo se detiene ahí de forma obligatoria:

1. **Generación:** la IA redacta la propuesta y se guarda en la tabla Propuestas con el checkbox “Aprobado” sin marcar.
2. **Notificación:** se avisa al equipo por Slack con el lead, la clasificación VIP, la confianza de la IA y la propuesta completa, para revisarla sin abrir Airtable a ciegas. El mensaje indica que hay 5 minutos para aprobar, y su timestamp se guarda en la propuesta (Slack Thread TS) para responder después en ese mismo hilo.
3. **Espera real:** el flujo se pausa (nodo Wait). No existe ningún camino que llegue al envío por Gmail sin pasar por el filtro que verifica el checkbox.
4. **Filtro explícito:** “Filtro: ¿Aprobado?” es la única puerta hacia el envío, y evalúa el valor recién leído de Airtable en cada ciclo (comparación booleana). Si no está tildado, vuelve al paso 3.
5. **Registro de la aprobación:** si está tildado, “Marcar Lead: Aprobado por Humano” deja constancia en el Estado del lead antes de que “Enviar Propuesta (Gmail)” contacte al cliente; al terminar, el lead pasa a Enviado y el sistema confirma el envío como respuesta en el mismo hilo de Slack del aviso.
6. **Si no se aprueba:** el sistema no espera para siempre ni asume aprobación. Al agotar los 5 ciclos (ver 2.4) marca el lead como Rechazado y lo registra en Errores. El silencio nunca se interpreta como luz verde.

La revisión humana no es un trámite: en la prueba de Diego Torres (#754) la IA mencionó un plazo típico de implementación (“4 a 8 semanas”) pese a que el prompt pide no comprometer plazos sin contexto del cliente. Justamente para detectar ese tipo de desvío ninguna propuesta llega al cliente sin que una persona la lea y la apruebe.

Evidencia: la ejecución #752 (Sofía Paz, VIP) y la #753 (Carla Díaz, no VIP) muestran el envío solo después de tildar “Aprobado” (con el paso por Aprobado por Humano); la #754 (Diego Torres) muestra el corte por timeout sin ningún email enviado.